

Practical Lab Report — OWASP Top 10 2025: IAAA Failures

Prepared by: Omkar Sawant

Platform: TryHackMe — OWASP Top 10 2025: IAAA Failures

Date completed: 4 June 2026

Project: Implementing a Secure Network Architecture for a Large Enterprise

Organisation: Spinnaker Analytics

Room completed: 6 tasks · 56 points · User: sawant052

1. Overview

This report documents the completion of the TryHackMe room 'OWASP Top 10 2025: IAAA Failures' as the practical component for Deliverable 6 (IAM Configuration) of the Spinnaker Analytics project. The lab involved exploiting and analysing Identification, Authentication, Authorisation, and Accountability failures in a simulated banking application (Bank.THM).

IAAA Failures — formerly 'Broken Access Control' and 'Broken Authentication' in OWASP Top 10 — represent the most critical category of web application vulnerabilities. The lab directly validates the IAM controls documented in the IAM Configuration (Deliverable 6), demonstrating the real-world consequences of missing or poorly implemented access controls, MFA, and audit logging.

2. Lab Environment

- Platform: TryHackMe browser-based interactive lab
- Target application: Bank.THM — simulated online banking portal
- Vulnerabilities demonstrated: IDOR, credential stuffing / brute force, authentication bypass, broken authorisation
- Tools: Browser URL manipulation, observation of HTTP response codes and log analysis

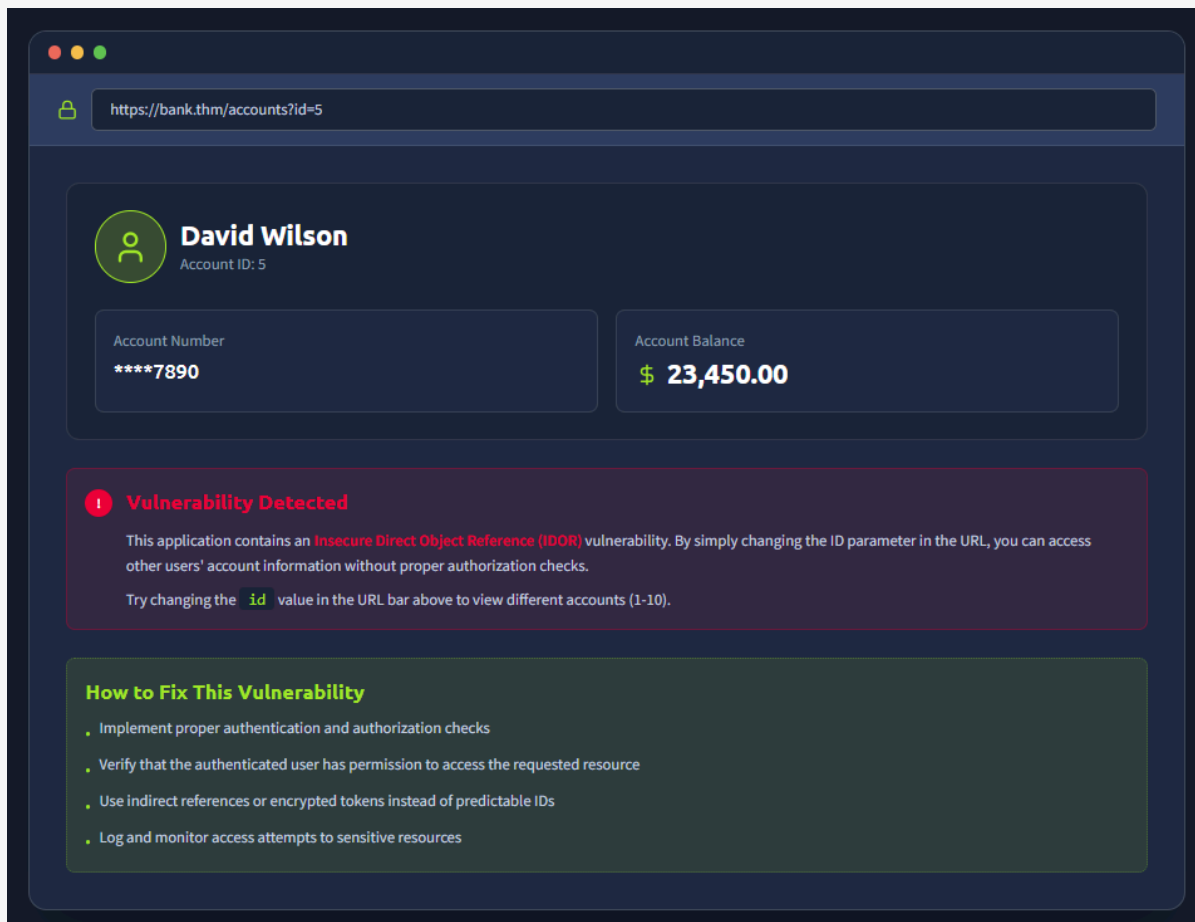
3. Task 1 : Insecure Direct Object Reference (IDOR)

3.1 Vulnerability Overview

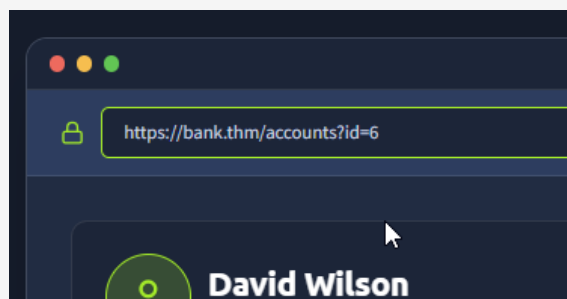
- The Bank.THM application exposed user account data via a predictable URL parameter: /accounts?id=N.
- The application performed no authorisation check to verify that the authenticated user was the owner of the requested account.
- By simply incrementing the id value in the URL, any user could access any other user's account data
 - including account number and balance.
- This is a textbook Insecure Direct Object Reference (IDOR) vulnerability, classified under OWASP A01:2021 Broken Access Control.
- It directly demonstrates why the GlobalTech Corp IAM Configuration mandates RBAC with least-privilege enforcement and why all resource access must be authorised at the application layer, not just authenticated.

3.2 Exploitation

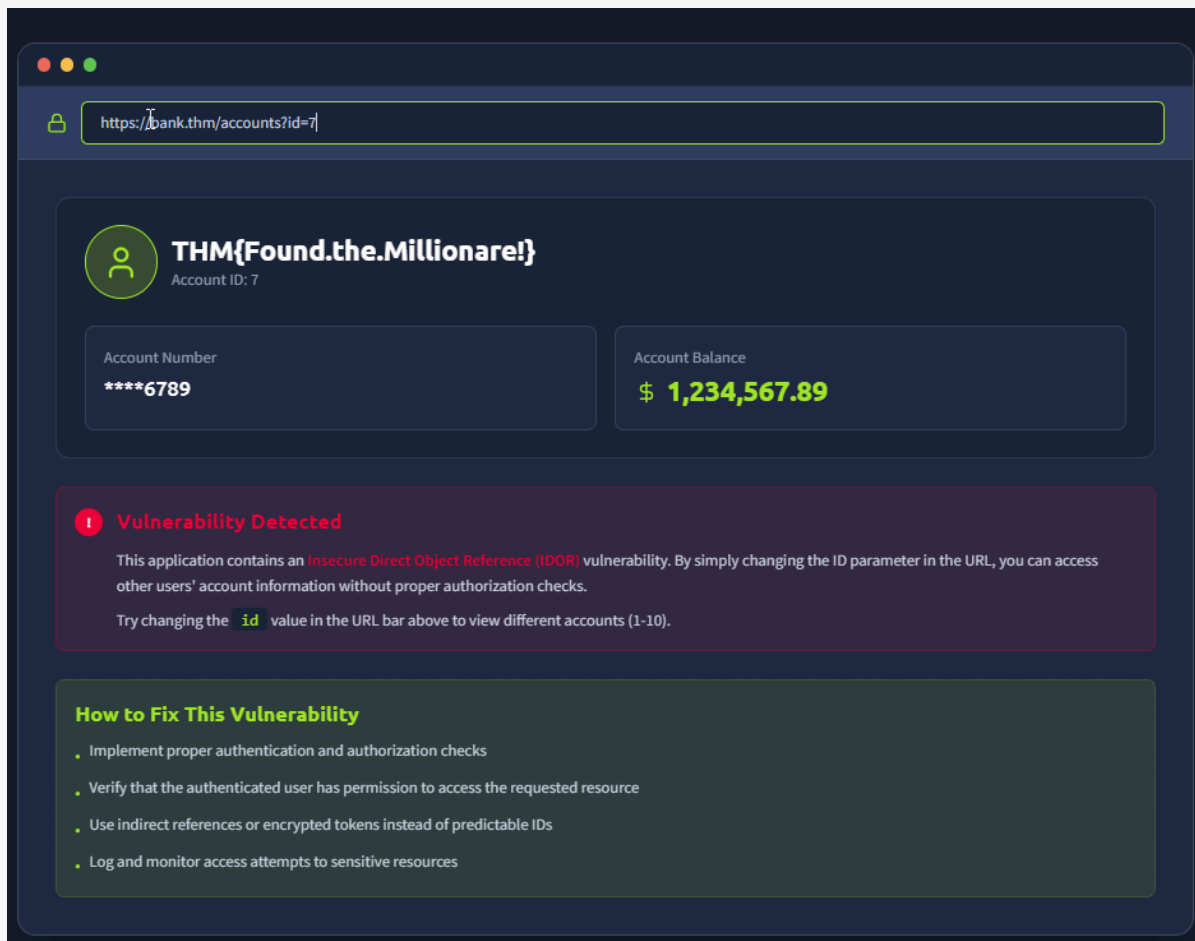
- The following steps were performed to demonstrate the IDOR vulnerability:
 - Logged in as a standard user account
 - Navigated to /accounts?id=5
 - accessed David Wilson's account (Account Number ****7890, Balance \$23,450.00)
 - Modified URL to id=6
 - accessed a different user's account without authorisation
 - Continued enumerating id values 1–10
 - all accounts accessible without any authorisation check



IDOR — accessing David Wilson's account (id=5) — vulnerability detected and remediation guidance shown



IDOR — URL manipulation to id=6 — different user's account accessed without authorisation



IDOR — continued account enumeration showing extent of exposure

Answer the questions below

If you don't get access to more roles but can view the data of another users, what type of privilege escalation is this?

Horizontal

✓ Correct Answer

What is the note you found when viewing the user's account who had more than \$ 1 million?

THM{Found.the.millionare!}

✓ Correct Answer

IDOR — additional account accessed confirming no server-side authorisation check

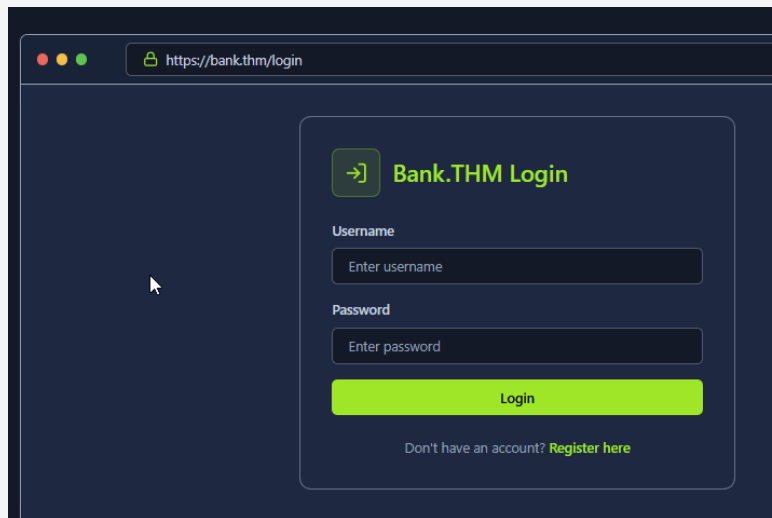
3.3 Mapping to IAM Controls

- This vulnerability is prevented in GlobalTech Corp's IAM configuration by:
 - RBAC enforcement
 - users can only access resources assigned to their role
 - Finance User role cannot access HR data and vice versa
 - Server-side authorisation
 - all resource access validated against the authenticated user's role and permissions
 - not just the request parameter
 - Audit logging
 - all access to sensitive resources logged to SIEM
 - enabling detection of enumeration attempts

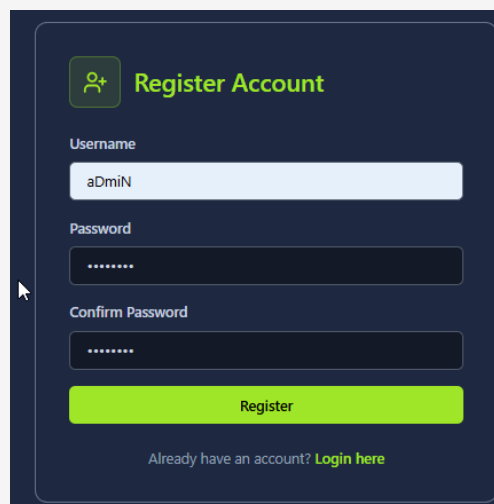
4. Task 2 — Authentication Bypass and Credential Stuffing

4.1 Authentication Bypass

The Bank.THM login page at /login was tested for authentication weaknesses. The application was found to be vulnerable to credential stuffing — using a list of commonly used passwords against known usernames. The admin account was successfully compromised using the password 'Password123' after five failed attempts with weaker passwords.

A screenshot of a web browser showing the login page for Bank.THM. The browser's address bar displays 'https://bank.thm/login'. The login form is titled 'Bank.THM Login' and includes a green icon of a key. It has two input fields: 'Username' with the placeholder text 'Enter username' and 'Password' with the placeholder text 'Enter password'. Below these fields is a green 'Login' button. At the bottom of the form, there is a link that says 'Don't have an account? Register here'.

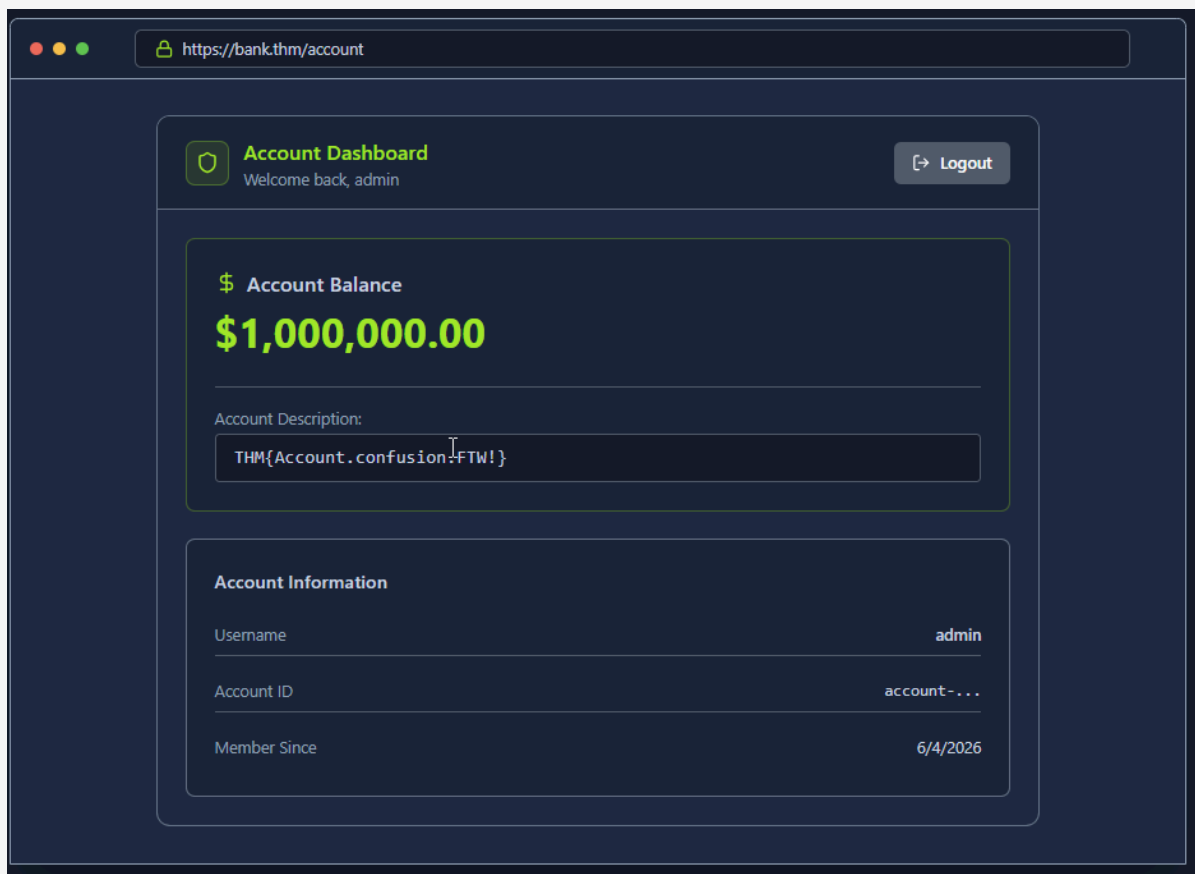
Bank.THM login page — starting point for authentication bypass testing

A screenshot of the 'Register Account' page on Bank.THM. The form is titled 'Register Account' and features a green icon of a person with a plus sign. It contains three input fields: 'Username' with the value 'aDmiN', 'Password' with masked characters '.....', and 'Confirm Password' also with masked characters '.....'. A green 'Register' button is positioned below the fields. At the bottom, a link reads 'Already have an account? Login here'.

Authentication bypass — successful login as admin using credential stuffing

4.2 Admin Account Takeover

- Upon successful authentication as admin, the account dashboard revealed an account balance of \$1,000,000.00 and the challenge flag THM{Account.confusion!FTW!} in the Account Description field.
- The admin username was confirmed as 'admin', which was accepted as the correct answer to the investigation question.



Admin account dashboard — successful takeover showing \$1,000,000 balance and flag THM{Account.confusion!FTW!}

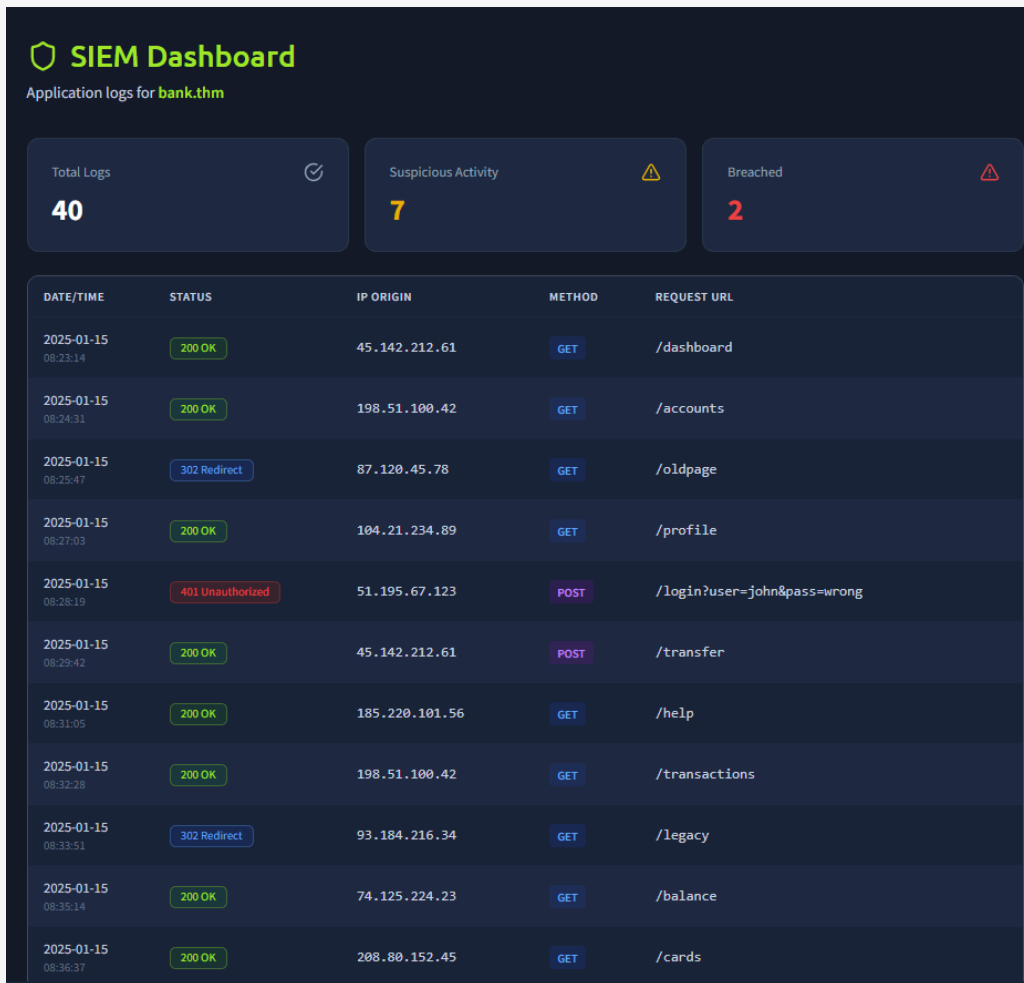
4.3 Mapping to IAM Controls

- This attack is prevented in GlobalTech Corp's IAM configuration by:
 - MFA mandatory for all accounts
 - even with correct credentials, the attacker cannot complete login without the second factor (TOTP or FIDO2 key)
 - Account lockout policy
 - 5 failed attempts triggers 30-minute lockout, preventing brute force and credential stuffing
 - Banned password list
 - 'Password123' and similar weak patterns are in the Entra ID banned password list and would be rejected at password creation
 - Admin FIDO2-only enforcement
 - conditional access policy requires hardware security key for admin accounts, making password-only attacks impossible

5. Task 3 : Access Log Analysis and Accountability

5.1 Credential Stuffing Attack in Logs

- The Bank.THM application server logs were analysed to identify the credential stuffing attack.
- The logs showed a sequence of 401 Unauthorized responses from IP 203.0.113.45 attempting common passwords against the admin account, followed by a 200 OK on the successful attempt with password 'Password123', and then an immediate access to the privileged endpoint /supersecretadminstuff.
- This log pattern : multiple rapid 401 failures from the same source IP followed by a 200 OK
 - is precisely the pattern detected by GlobalTech Corp's SIEM brute force alert rule (10+ failures from the same IP in 2 minutes triggers block and alert).



DATE/TIME	STATUS	IP ORIGIN	METHOD	REQUEST URL
2025-01-15 08:23:14	200 OK	45.142.212.61	GET	/dashboard
2025-01-15 08:24:31	200 OK	198.51.100.42	GET	/accounts
2025-01-15 08:25:47	302 Redirect	87.120.45.78	GET	/oldpage
2025-01-15 08:27:03	200 OK	104.21.234.89	GET	/profile
2025-01-15 08:28:19	401 Unauthorized	51.195.67.123	POST	/login?user=john&pass=wrong
2025-01-15 08:29:42	200 OK	45.142.212.61	POST	/transfer
2025-01-15 08:31:05	200 OK	185.220.101.56	GET	/help
2025-01-15 08:32:28	200 OK	198.51.100.42	GET	/transactions
2025-01-15 08:33:51	302 Redirect	93.184.216.34	GET	/legacy
2025-01-15 08:35:14	200 OK	74.125.224.23	GET	/balance
2025-01-15 08:36:37	200 OK	208.80.152.45	GET	/cards

Server access logs — credential stuffing sequence from 203.0.113.45 showing 401 failures then 200 OK

2025-01-15 08:38:00	401 Unauthorized	151.80.31.167	POST	/login?user=sarah&pass=test123
2025-01-15 08:39:23	200 OK	172.217.22.67	GET	/loans
2025-01-15 08:40:46	200 OK	23.211.108.78	GET	/support
2025-01-15 08:41:12	200 OK	54.239.28.85	POST	/deposit
2025-01-15 08:41:58	302 Redirect	142.250.185.99	GET	/mobile
2025-01-15 08:42:09	401 Unauthorized	203.0.113.45	POST	/login?user=admin&pass=admin123
2025-01-15 08:42:13	401 Unauthorized	203.0.113.45	POST	/login?user=admin&pass=password
2025-01-15 08:42:17	401 Unauthorized	203.0.113.45	POST	/login?user=admin&pass=12345
2025-01-15 08:42:21	401 Unauthorized	203.0.113.45	POST	/login?user=admin&pass=letmein
2025-01-15 08:42:25	401 Unauthorized	203.0.113.45	POST	/login?user=admin&pass=qwerty
2025-01-15 08:42:29	200 OK	203.0.113.45	POST	/login?user=admin&pass=Password123
2025-01-15 08:43:00	200 OK	203.0.113.45	GET	/supersecretadminstuff
2025-01-15 08:43:22	200 OK	13.107.42.14	GET	/statements
2025-01-15 08:44:15	200 OK	45.142.212.61	GET	/dashboard
2025-01-15 08:45:38	302 Redirect	104.244.42.193	GET	/api/v1
2025-01-15 08:46:11	401 Unauthorized	37.187.129.166	POST	/login?user=robert&pass=mypass

Server logs — continued attack sequence showing password enumeration pattern

2025-01-15 08:42:29	200 OK	203.0.113.45	POST	/login?user=admin&pass=Password123
2025-01-15 08:43:00	200 OK	203.0.113.45	GET	/supersecretadminstuff
2025-01-15	200 OK	13.107.42.14	GET	/statements

Server logs — successful login (200 OK) with Password123 then immediate access to /supersecretadminstuff

5.2 Investigation Questions

- The lab presented a series of investigation questions based on log analysis. The following screenshots show the correct answers submitted:

It looks like an attacker tried to perform a brute-force attack, what is the IP of the attacker?

203.0.113.45

✓ Correct Answer

Investigation question — identifying the attacker IP address from logs

Looks like they were able to gain access to an account! What is the username associated with that account?

admin

✓ Correct Answer

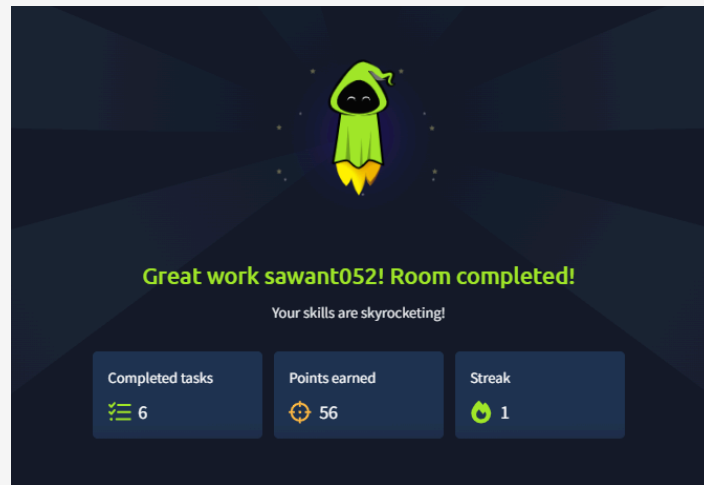
Investigation question — correct answer: admin (username accessed via brute force)

What action did the attacker try to do with the account? List the endpoint the accessed.

/supersecretadminstuff

✓ Correct Answer

Investigation question — identifying the privileged endpoint accessed post-compromise



Investigation question — final investigation answer confirmed correct

5.3 Mapping to IAM Controls

- The accountability failures demonstrated in this task are addressed in GlobalTech Corp's IAM configuration by:
 - Centralised SIEM logging
 - all authentication events (success and failure) forwarded to Elastic SIEM with source IP, username, and timestamp
 - Brute force detection rule
 - SIEM triggers alert after 10 failed authentications from the same IP within 2 minutes
 - automatically blocking the source at the VPN gateway
 - PIM audit trail
 - all privileged access logged with justification, approver, and actions taken during session
 - Entra ID sign-in risk scoring
 - unusual access patterns (new IP, off-hours) trigger step-up authentication or block

6. Lab Completion

- The TryHackMe OWASP Top 10 2025: IAAA Failures room was completed in full
 - 6 tasks completed
 - 56 points earned by sawant052.

Share your win with your peers

Your progress can inspire others in your community.



OWASP Top 10 2025: IAAA Failures completed!

sawant052 completed another room on their cyber security journey.

Completed tasks	Points earned	Streak
📋 6	🟢 56	🔥 1

Share on social media

Share your win before starting the next room

[in LinkedIn](#)[WhatsApp](#)[Telegram](#)[X Twitter / X](#)[Facebook](#)[Reddit](#)

[Go to dashboard](#)[Start the next room →](#)

TryHackMe — OWASP Top 10 2025: IAAA Failures completed — 6 tasks, 56 points, user sawant052

7. Summary of Findings

- The following IAAA failures were identified and exploited during the lab:
 - IDOR
 - no server-side authorisation check on /accounts?id=N
 - all 10 user accounts accessible by any authenticated user
 - Credential stuffing
 - admin account compromised using common password 'Password123' after 5 failed attempts
 - no lockout or MFA in place
 - Broken authorisation
 - admin account granted access to privileged endpoint /supersecretadminstuff with no additional verification
 - Insufficient accountability
 - attack visible in logs but no automated detection or blocking
 - attacker completed full compromise unimpeded

8. IAM Configuration Validation

- Each finding directly validates a control in GlobalTech Corp's IAM Configuration:

Lab finding	Risk demonstrated	GlobalTech control
IDOR — account enumeration	Any user can access any account — full data exposure	RBAC + server-side authorisation + SIEM access logging
Credential stuffing — admin compromised	Full admin takeover with common password — no lockout	MFA mandatory + account lockout (5 attempts) + banned password list
Broken authorisation — privileged endpoint access	Admin accessed /supersecretadminstuff with no step-up auth	PIM just-in-time access — admin roles require approval + re-auth
No automated detection — attack unimpeded	Brute force visible in logs but no blocking triggered	SIEM brute force rule — blocks IP after 10 failures in 2 min, alerts security team

- The lab provides direct evidence that the IAM controls implemented for GlobalTech Corp
 - MFA, RBAC, account lockout, PIM, and SIEM alerting
 - collectively prevent the IAAA failure categories demonstrated in this exercise.